

L2-06

Segurança de software é a disciplina que projeta, constrói e mantém programas resistentes a ataques, falhas e abusos. Diferente da segurança da informação (mais ampla) e da segurança de redes (foco em tráfego), ela atua sobre o próprio código e suas dependências.

A importância vem do fato de que todo software tem defeitos, e parte deles é explorável. Cada falha pode causar prejuízo financeiro, vazamento de dados pessoais, perda de confiança e, em sistemas críticos, risco à vida. Com a nuvem e a economia digital, o impacto é amplificado: uma vulnerabilidade atinge milhões de usuários ao mesmo tempo.

Apóia-se na tríade CIA:

- Confidencialidade - só quem tem permissão acessa o dado;
- Integridade - o dado não é alterado sem autorização;
- Disponibilidade - o sistema fica acessível quando necessário.

É importante distinguir ameaça (agente que causa dano), vulnerabilidade (a falha que permite o dano) e risco (probabilidade x impacto).

Bons práticas: pensar em segurança desde os requisitos (security by design), aplicar defesa em profundidade (barreiras como camadas), usar o menor privilégio, validar entradas e revisar código. Frameworks como Microsoft SDL, OWASP SAMM e NIST SSDF orientam uma boa parte do ciclo de vida.

Conclusão: segurança não é etapa final, é atributo de qualidade. Corrigir um defeito em produção pode custar até 100x mais que em projeto. Integrá-la desde o início reduz custos e protege usuário.